

Herfree 법률 자문용 사실 정리서

작성 목적: 변호사·개인정보 전문가가 기술 설명 없이 적법성·처리방침·오픈 가능 여부를 판단할 수 있도록 사실만 정리
서비스: Herfree(헤르프리) · 도메인 herpfree.co.kr · 2026년 7월 기준

※ 본 문서는 법률 자문이 아닙니다. 아래는 실제 서비스·시스템이 무엇을 하는지만 적었습니다.
적법 여부는 수임 변호사가 판단해 주세요.

1. 서비스가 무엇인가요?

한 줄 설명	헤르페스(HSV) 관련 고민을 나누는 익명 건강 커뮤니티 + 나만 보는 건강 일지 웹사이트
하지 않는 것	병원 진료·진단·처방·원격진료, AI 의료 상담, 결제, 스마트폰 앱(1차 버전)
약관상 성격	「의료행위를 제공하지 않으며, 게시물·정보는 참고용」
이용 대상	가입 시 「만 14세 이상」 확인 체크 (별도 나이·법정대리인 검증은 없음)

2. 변호사에게 꼭 봐달라고 할 질문 (10가지)

- 증상·투약·건강 메모 등 민감정보(건강정보)를 저장하는 것이 적법한가? (동의 문구·처리방침 포함)
- 이 서비스가 의료행위·의료기기·의료광고에 해당하는가?
- 현재 개인정보처리방침·이용약관과 실제 운영이 맞는가? 수정안은?
- AWS(서울)에 데이터를 두는 것 — 위탁·국외 이전 고지가 충분한가?
- 카카오·네이버·구글 로그인 — 제3자 제공·위탁 고지가 필요한가?
- 만 14세 미만 — 지금처럼 체크만으로 충분한가?
- 익명 통계(20명 이상일 때만 공개) — 법적으로 문제없는가?
- 회원 탈퇴·데이터 삭제 방식이 적법한가? 보관 기간은 어떻게 적을까?
- 실서비스 오픈 전 필수 vs 나중에 해도 되는 것 구분
- 개인정보 보호책임자·사업자 정보 — 처리방침에 무엇을 넣어야 하는가?

3. 운영 주체 (⚠ 의뢰인이 채워야 함)

→ 자문 전에 의뢰인에게 아래를 받아 변호사에게 함께 전달하세요.

사업자(또는 예정 법인)명	()
대표자	()
사업장 주소	()
개인정보 보호책임자	성명 · 직책 · 연락처 ()

4. 회원 정보는 어디에 저장되나요?

모두 **Amazon Web Services(AWS) · 한국(서울) 리전**입니다. 테스트용(staging)과 실서비스(production)는 **완전히 분리**되어 있습니다.

저장 종류	설명
회원·게시글·일지 DB	AWS RDS MySQL (운영 전용 DB, 인터넷에서 DB 직접 접속 불가)
게시글 사진	AWS S3 (비공개 버킷, 웹사이트를 통해서만 조회)
웹사이트 화면	AWS Amplify (프론트)
API 서버	AWS EC2 (Docker로 앱 실행, HTTPS만 공개)
비밀번호·설정	AWS Secrets Manager (코드·GitHub에 넣지 않음)
접속 기록·로그	AWS CloudWatch (일부 보존 기간은 아직 확정 전)

5. 무엇을 입력·수집하나요?

① 회원가입 (필수)

항목	설명
이메일	로그인 ID
비밀번호	암호화해서 저장 (평문 저장 안 함)
닉네임	커뮤니티 표시명
약관·개인정보 동의	필수
민감정보(건강정보) 동의	필수 — 거부 시 가입·일지 불가
만 14세 이상	필수 체크
마케팅 수신	선택
건강정보 통계 활용	선택 — 거부해도 기본 기능 이용 가능, 나중에 철회 가능

② 소셜 로그인 (카카오·네이버·구글)

각 서비스에서 받은 **고유 ID**만 저장합니다. Herfree 계정과 연결하는 용도입니다.

③ 개인 일지 (본인만 볼 수 있음 — 민감정보)

사용자가 직접 입력·선택합니다.

- 날짜, 증상 있음/없음, 증상 강도(1~5)
- 전조 증상·유발 요인 (목록에서 선택)
- 투약 여부, 수면, 스트레스, 기분, 영양제, 운동
- **자유 메모** — 사용자가 직접 쓰는 글 (현재 DB에 **일반 텍스트**로 저장)

운영자는 개별 일지 원문을 보는 화면/API는 없습니다. (건수·익명 집계만)

처리방침에는 「운영자가 필요한 범위에서 접근」 문구가 있어, **문구와 실체가 맞는지** 변호사 확인 필요.

④ 커뮤니티 (게시글·댓글)

- 제목·본문·닉네임 또는 「익명」 표시 (내부적으로 작성자 연결은 유지 — 신고·관리용)
- 공개 게시판 + **비공개** 게시판(1:1 문의, 비밀상담, 비밀사연) — 비공개는 **작성자**와 **운영자**만 열람
- 사진 첨부: JPG·PNG·WEBP, 최대 10MB
- 가이드: 「구체적 진단명·의료기록은 올리지 말 것」 — **강제 필터는 없음** (사용자 자유 입력)

⑤ 그 밖에

- 비밀번호 재설정: 이메일로 링크 발송 (토큰은 해시만 저장)
- 이용 통계: 「가입 완료」「로그인」 등 **행동 종류**만 — 이메일·일지·글 내용은 **넣지 않음**

6. 제3자 · 외부 연동

업체	역할
Amazon Web Services	서버·DB·파일 저장 (한국 서울)
카카오·네이버·구글	로그인 인증
이메일(SMTP)	비밀번호 재설정 메일 발송
Gabia	도메인 이름 연결(DNS)만 — 회원 데이터 저장 없음

하지 않는 것: 회원 정보 판매, 광고 추적 SDK, AI 학습용 외부 전송, 결제대행

7. 회원 탈퇴 시 어떻게 되나요?

- 이메일·비밀번호·소셜 연결 → **삭제·비식별 처리**
- 개인 일지 → **전부 삭제**
- 게시글·댓글 → **익명 처리** (커뮤니티 맥락 유지)
- 게시글 사진 → S3에서 **삭제**

로그·백업 보관 **구체 기간**은 처리방침에 아직 상세히 안 적혀 있음 → 변호사와 정할 것.

8. 보안 (비전문가용 요약)

적용됨	HTTPS, 비밀번호 암호화, 타인 일지 접근 차단, DB 암호화(저장), 관리자 권한 분리
아직 약함	일지 메모 추가 암호화 없음(평문) , 관리자 2단계 인증 없음, 운영 DB 자동 백업 1일(Free tier)

9. 테스트 데이터 · DB 「밀기」

테스트(staging) DB	QA용 — 운영과 별개 . 지워도 운영에 영향 없음
운영(production) DB	실제 회원 데이터 . 통째 초기화 금지(실사용자 생기면). 오픈 전 테스트 계정만 선별 삭제
자동 데모 데이터	운영·테스트 서버 모두 자동 생성 안 함 (개발 PC만)

10. 변호사 판단 시 알아둘 「아직 안 맞거나 미완」

- 사업자·보호책임자 정보 미기재
- 처리방침 「운영자 일지 접근」 vs 실제(개별 조회 없음)
- 보유·파기 기간 숫자 미확정
- 일지 메모 평문 저장
- 만 14세 — 확인만, 법정대리인 동의 없음
- 운영 RDS 백업 1일 (장기 보관 권장은 7일+)

11. 함께 보내면 좋은 자료

- 웹사이트 「개인정보처리방침」「이용약관」 화면 캡처
- 회원가입 동의 화면 캡처
- 본 PDF
- 실제 회원 DB 데이터는 보내지 마세요

Herfree Platform · 법률 자문용 사실 정리 · 기술팀 작성 · 법적 효력 없음

상세 기술 문서: [docs/health-data-security-standard.md](#), [docs/go-live-checklist.md](#)